

AI SOC Incident Report

As a Senior SOC Analyst, here's my analysis of the provided content:

Security Incident Analysis Report

Content Analyzed:

...

2025-06-06 14:35:22 Failed login attempt from 192.168.1.100
2025-06-06 14:35:30 Failed login attempt from 192.168.1.100
2025-06-06 14:35:38 Failed login attempt from 192.168.1.100
2025-06-06 14:35:45 Failed login attempt from 192.168.1.100
2025-06-06 14:35:50 User admin locked due to multiple failures

...

1. **Threat Type:**
Brute-Force Attack / Password Guessing
2. **Severity:**
Medium
*While the attack was mitigated by the account lockout policy, preventing immediate compromise,
3. **Risk Score (0-100):**
65
*This score reflects the potential high impact of an `admin` account compromise, the proven inte
4. **MITRE ATT&CK Technique:**
 - * **Tactics:** Credential Access (TA0006)
 - * **Technique:** T1110 - Brute Force
 - * **Sub-technique:** T1110.001 - Brute Force: Password Guessing
5. **Indicators of Compromise (IOCs):**
 - * **Source IP Address:** 192.168.1.100
 - * **Targeted User Account:** `admin`

- * **Event Pattern:** Multiple failed login attempts in rapid succession (within 28 seconds).

6. **Explanation:**

At 2025-06-06 14:35:22, a series of rapid failed login attempts began originating from the inter

7. **Recommended Actions:**

Immediate Actions (Containment & Eradication):

- * **Verify Admin Account Status:** Confirm the `admin` account is indeed locked.
- * **Isolate Source IP:** Immediately isolate or block network access for the IP address `192.168.1.100`.
- * **Investigate Source Host:**
 - * Identify the device associated with `192.168.1.100` (e.g., using DHCP logs, CMDB, network monitoring tools).
 - * If it's an authorized device, contact the owner/user to determine if they were attempting unauthorized access.
 - * If it's a server/workstation, perform a full malware scan, check running processes, and review logs for suspicious activity.
 - * If it's an unauthorized device, take steps to remove it from the network.
- * **Reset Admin Password:** Once the investigation has progressed and the risk is assessed, reset the admin password to a strong, unique value.
- * **Unlock Admin Account:** Only unlock the `admin` account after the source of the brute-force attempt has been identified and mitigated.

Further Investigation (Eradication & Recovery):

- * **Log Review:**
 - * Review authentication logs on other critical systems (e.g., domain controllers, critical servers) for any similar activity.
 - * Check logs for the `admin` user on the affected system for any successful logins immediately following the incident.
- * **Lateral Movement Check:** Investigate if the host at `192.168.1.100` has made any other successful connections or attempts to access other systems.
- * **Insider Threat Assessment:** If the host is identified as belonging to an employee, assess the risk of insider threat and take appropriate actions.

Long-Term Recommendations (Lessons Learned & Improvement):

- * **Multi-Factor Authentication (MFA):** Ensure MFA is enforced for *all* administrative accounts and critical system access.
- * **Account Lockout Policy Review:** Review and confirm the effectiveness of current account lockout policies and adjust if necessary.
- * **Network Segmentation:** Enhance network segmentation to limit the blast radius of internal network compromises.
- * **Threat Hunting:** Proactively hunt for similar brute-force attempts or anomalous login patterns.
- * **User Behavior Analytics (UBA/UEBA):** Leverage UBA/UEBA solutions to detect and alert on unusual user behavior.
- * **Security Awareness Training:** Remind users about password hygiene and the importance of reporting suspicious activity.